

NationalBank Reserve — Executive Briefing

Mustafa Musa Ahmed

NationalBank Reserve

Red Team Engagement — Executive Briefing

5-Minute Stakeholder Presentation

Mustafa Musa Ahmed | 2026

The Bottom Line

Full compromise in under 15 minutes.

- No zero-days
 - No advanced tooling
 - Public exploits + 1 phishing email
-

What We Found

22 findings - 5 CRITICAL (full compromise) - 12 HIGH (data theft / takeover)
- 3 MEDIUM (defense erosion) - 2 LOW (info disclosure)

Overall risk: CRITICAL

Top 5 Critical Findings

1. **DB credentials exposed** via .bak file (CVSS 9.8)
2. **SQL Injection** in web app (CVSS 9.8)
3. **Command Injection** → **RCE** (CVSS 9.8)
4. **API Broken Authentication** (CVSS 9.8)
5. **API SQL Injection** (CVSS 9.8)

Attack Chain

1. Phishing email → credential capture
2. API broken auth → admin panel
3. BOLA → enumerate all users + API keys
4. Mass assignment → admin role
5. SQLi + command injection → root shell
6. SSRF → internal file read
7. Backup file → DB credentials

Time to compromise: < 15 min

Detection Evasion Result

- Signature-only AV: **bypassed by custom XOR**
 - Commercial encoder (shikata_ga_nai): **detected** (own signature)
 - **Conclusion:** signature-only AV is insufficient → need EDR
-

Business Impact (if production)

- All customer records extractable via SQLi
 - Any account takeover via BOLA
 - Full server control (RCE)
 - Internal file read (SSRF)
 - Regulatory exposure (PCI-DSS, RBI)
-

90-Day Roadmap

Days 0–7: CONTAIN

Rotate credentials • Delete .bak files • Enable DMARC/SPF/DKIM • WAF rules

Days 8–30: HARDEN

Patch software • Parameterized queries • API authorization • Deploy EDR

Days 31–90: MATURE

Phishing-resistant MFA • Segmentation • SIEM • Quarterly red team

Success Metrics

- Critical patched 7 days
 - High patched 30 days
 - Phishing click rate < 5%
 - 100% MFA on admin accounts
-

Recommendation

Treat Days 0–7 as urgent. Begin today.

Full report + evidence: [linked repository](#).

Thank you. Questions?